IT Configuration Management Policy

Effective Date:
October 1, 2026

Category:
Security

Scheduled Review:
October 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Purpose

This policy establishes requirements for secure and consistent configuration management of Commonwealth IT resources, aligned with recognized standards, to protect the confidentiality, integrity, and availability of Commonwealth information systems.

3. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

4. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

This policy applies to all Commonwealth IP-enabled hardware and/or software assets.

Agencies shall ensure compliance with this policy and the associated *IT Configuration Management Technology Standard* within twelve (12) months of the effective date. Agencies that are unable to comply after the twelve (12) month implementation period shall document the non-compliance through a policy exception and approved IT Risk Acknowledgement Form, in accordance with the enterprise IT policy waiver and risk acknowledgement processes.

4.1 Configuration Identification and Baselines

Baseline configurations shall reflect secure-by-default principles and implement least functionality appropriate to the system's purpose and operational requirements.

Agencies shall align their baseline configurations with Commonwealth-approved

benchmarks as defined in the *IT Configuration Management Technology Standard* and applicable regulatory or statutory requirements (e.g., CJIS, IRS, PCI), where required.

Baseline configurations shall be:

- Reviewed at least annually and upon significant system, environmental, or threat landscape changes; and
- Protected from unauthorized modification.

Approved baselines shall serve as the authoritative reference point for configuration change management, monitoring, and compliance validation.

4.2 Configuration Change Management

Configuration changes shall comply with the established change management policy and processes detailed in the *Change Management Policy.*

As part of the change management process, agencies are responsible for ensuring configuration changes are assessed based on their security impact and Risk.

Agencies shall restrict configuration and change privileges to authorized personnel based on defined roles and responsibilities. Access shall be granted in accordance with the principle of least privilege and shall be reviewed periodically to ensure continued appropriateness.

4.3 Monitoring and Auditing

Agencies are recommended to use automated tools, where feasible, to monitor configuration compliance and detect unauthorized changes.

Identified deviations from approved baseline configurations shall be documented, assessed for risk, and remediated within the same timeframes established in the Commonwealth Enterprise Patching Policy for the applicable asset classification.

Agencies shall maintain configuration compliance metrics and provide reporting as required by OA/IT.

4.4 Asset and Configuration Inventory & Classification

Agencies shall maintain authoritative inventories of all IP-enabled hardware and/or software assets subject to Commonwealth configuration management requirements.

Where possible configuration items shall be documented within a configuration management database (CMDB) or other enterprise tools linking assets to:

- Approved baselines
- System owners
- Operational environments
- Interconnections
- Change history

Inventories shall be updated during installation, removal, and modification activities.

4.5 Configuration Documentation and Record Retention

Agencies shall retain configuration documentation and related change records in accordance with applicable records retention schedules in accordance with the *Records Management Policy*.

4.6 Third-Party Service Providers Managing Cloud Configurations

The requirements of this policy extend to third-party providers, contractors, and cloud services that host or handle Commonwealth data and systems. Agencies must ensure that external service providers are managing configurations with equal rigor and in alignment with this policy.

5. Contact

Questions or comments may be directed via email to OA, IT Policy.

6. Exceptions

In the event an agency chooses to seek an exception from this policy, a request for a policy waiver shall be submitted via the enterprise IT policy waiver process. Refer to *IT Policy Governance Policy* for guidance.

7. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	10/01/2026	Base Document